INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — PaketPro 3000 Sürümü · Paketleme Makinesi

Tüm laboratuvarlar deck'in işlenmiş örnek makinesi PaketPro 3000'e uyarlanmıştır: sıcak çene + kesme bıçağı · ışık perdesi · 16 varlık + 5 dış bağlantı · internete açık uzak bakım modülü.

SEÇİLEN MAKİNE
Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

LABORATUVAR 1 · PAKETPRO 3000 · Paketleme Makinesi

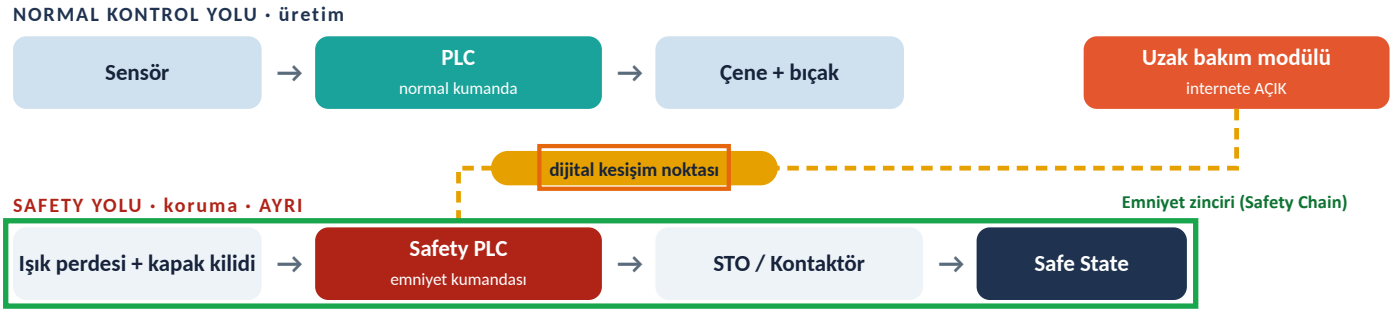
Safety Architecture

Çıktı: Safety Function Map

Makine: Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

Ad Soyad **Mehmet Sefa İmamoğlu** Grup **Gündüz B** Tarih **02.10.2026**

PaketPro bağlamı: Sıcak yapıştırma çenesi ve film kesme bıçağı el/parmak için ciddi tehlikedir; koruma **ışık perdesi + kapak kilidi → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Yüksek devirli ön freze, kazıma ve baş-son kesme testereleri (12.000–18.000 RPM) uzuv kesilmesi/sıkışması; 180–210°C PUR tutkal kazanı ise ağır yanık, yangın ve izosiyanat buharı tehlikesi yaratır.

2 Safety function (emniyet fonksiyonu) hangisidir?

Muhafaza kapağı açıldığında, acil stop basıldığında veya tutkal kazanı aşırı sıcaklığa ulaştığında Safety PLC'nin STO ile freze/testere tahriklerini kesmesi ve emniyet kontaktörüyle ısıtıcı enerjisini bağımsız keserek makineyi durdurmasıdır.

3 Safety-related control system nerede? Şemada işaretleyin.

Şemadaki alt emniyet zinciridir: Acil stop / kapak kilidi / termostat → Safety PLC → STO / Kontaktör → Safe State. (Şemada yeşil çerçeveyle işaretlendi.)

4 Normal PLC ile Safety PLC farkı nedir?

Normal PLC üretimi yönetir: tutkal sıcaklık PID'si, VFD devirleri, pnömatik zamanlama. Safety PLC ise emniyet girişlerini izler, kendi kendini denetler ve arızada makineyi güvenli duruma geçirir; üretim PLC'sinden bağımsız çalışır.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr/SIL, emniyet fonksiyonunun riske göre ne kadar güvenilir olması gerektiğini belirler. Freze takımı ve 200°C tutkal ağır yaralanma riski taşıdığı için yüksek PLr/SIL (ör. PL d–e) gerekir.

6 Safe state (güvenli durum) nedir?

Tahriklerin torku kesilmiş (STO), muhafazalar motorlar durana dek kilitli, ısıtıcı kontaktörü açık ve pnömatik enerji tahliye edilmiş; makinenin istemsiz yeniden kalkışı engellenmiş durumdur. Kazanın kalan sıcaklığı ayrıca korunur.

7 Safety function hangi dijital bağımlılıklara sahip?

Safety PLC yazılımı ve yapılandırması, emniyet I/O ve sensör sinyalleri, emniyet haberleşmesi, VFD'lerin STO girişleri ve sıcaklık limit parametreleri. Bu bileşenlerin bütünlüğü korunmalıdır.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

İnternete açık uzak bakım modülü / IPC ile üretim PLC'si arasındaki dijital kesişim noktasıdır. Saldırgan buradan Safety PLC yapılandırmasını, sıcaklık limitini veya VFD parametrelerini değiştirirse emniyet fonksiyonu devre dışı kalabilir.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · PAKETPRO 3000 · Paketleme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Makine: Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

Ad Soyad **Mehmet Sefa İmamoğlu** | Grup **Gündüz B** | Tarih **09.10.2026**

> **Kavram: Zone** = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1 Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Z1 Emniyet: Safety PLC, acil stop, kapak kilitleri, aşırı sıcaklık termostatı | Z2 Üretim: Üretim PLC'si, tutkal ısı kontrolü, mühendislik istasyonu | Z3 Saha/Tahrik: Freze ve testere VFD'leri, ısıtıcılar, pnömatik valfler | Z4 Operatör: HMI (port 80) | Z5 DMZ: Uzak bakım modülü, jump server | Z6 Dış: Wi-Fi AP, bulut telemetri, ofis ağı. Not: Kilitsiz USB ve admin/admin ayrı bölge değil, kapatılacak açıklardır.

2 Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Uzak bakım modülü Z5 (DMZ) bölgesine düşer ve internete doğrudan açık HAYIR kalamaz: yetkisiz erişim freze devrini ve tutkal ısısını değiştirebilir. VPN + MFA + jump server + güvenlik duvarı arkasına alınmalı, varsayılan kapalı olmalıdır.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

1) DMZ → Üretim PLC: VPN/MFA, izinli IP-port, oturum kaydı, yazma koruma anahtarı. 2) HMI → PLC: yalnızca tanımlı etiketler, yetki kontrolü. 3) Üretim PLC ↔ Safety PLC: tek yönlü durum bilgisi, parametre yazımı yasak. 4) PLC → VFD: devir/sıcaklık sınır filtresi. 5) Wi-Fi/Ofis → OT: OT güvenlik duvarı, varsayılan engelleme.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: Doğrudan PLC erişimini engeller, tüm bakım erişimi tek denetimli noktadan geçer.
Tünel?	Açık / VPN	VPN: Bakım trafiği şifrelenir, yalnızca yetkili kaynak bağlanabilir.
Kimlik?	Parola / MFA	MFA: Parola çalınsa bile ikinci doğrulama olmadan oturum açılamaz.
Hesap?	Paylaşılan / Kişisel	Kişisel: Her teknisyen ayrı hesap kullanır; işlemler kişiye bağlanır.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: Parametre değişiklikleri denetlenebilir, delil olur.
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: Erişim yalnızca onaylı bakım süresince açılır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · PAKETPRO 3000 · Paketleme Makinesi

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Makine: Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

Ad Soyad **Mehmet Sefa İmamoğlu** Grup **Gündüz B** Tarih **16.10.2026**

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Dış saldırgan → açık uzak bakım modülü → freze VFD devrini yükseltir → takım parçalanır → fırlayan parça operatörü ağır yaralar.	3	3	3	27	Kritik
Yetkisiz kişi → zayıf Wi-Fi/HMI → tutkal set değerini yükseltir → PUR aşırı ısınır → yangın/toksik buhar, operatör yanar.	2	3	2	12	Yüksek
Yetkisiz kişi → kilitsiz USB → hatalı yazılım kapak kilidi sinyalini atlatır → muhafaza açıkken testere döner → el yaralanır.	1	3	1	3	Düşük (S=3!)

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

1. senaryo (27 – Kritik) en önceliklidir; çünkü açık uzak bakım modülü olasılığı yükseltir, fırlayan freze takımı ise operatör için ölümcül/ağır yaralanma sonucu doğurur.

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

Evet, 3. senaryonun skoru 3 (Düşük) ama S=3'tür. Risk Register'da "Kritik Fiziksel Sonuç (S=3)" uyarısıyla kırmızı işaretleyip emniyet önlemlerini (kapak kilidi izleme, USB kilidi, güvenli duruş testi) önceliklendireceğim.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · PAKETPRO 3000 · Paketleme Makinesi

Secure Remote Access

Çıktı: Secure Architecture

Makine: Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

Ad Soyad **Mehmet Sefa İmamoğlu** Grup **Gündüz B** Tarih **23.10.2026**

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: uzak bakım modülü bugün internete DOĞRUDAN açık.

- Uzak bakım modülü internete doğrudan açık.
- admin/admin ortak hesabı kullanılıyor; MFA ve oturum kaydı yok.
- Freze VFD devri ve tutkal sıcaklığı OT ağı üzerinden yazılabiliyor.
- Üretim PLC'si ile emniyet sistemi arasında izole olmayan dijital bağlantı var.

HEDEF (beş ilkeyle yeniden tasarlayın)

1) Erişim yalnızca DMZ'deki jump server üzerinden.
2) VPN + MFA ile kimlik doğrulama.
3) Kişisel hesap, asgari yetki.
4) Tam oturum kaydı; erişim varsayılan kapalı.
5) Safety PLC bağımsız; VFD/sıcaklık parametreleri yazma koruma anahtarıyla kilitli.

Görev B — functional safety köprüsü

1 Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

Evet, emniyet sistemi üretim/uzak erişim ağına bağımlıysa etkilenir: içeri giren saldırgan sıcaklık limitini, VFD parametrelerini veya emniyet yapılandırmasını bozabilir. Bu yüzden emniyet fonksiyonu erişim güvenliğinden bağımsız çalışmalıdır; erişim kontrolleri tek başına insan güvenliğini garanti etmez.

2 Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

Üretim ağı veya uzak bakım yolu ele geçirilse, çökse ya da yanlış komut verse bile; kapak açılması, acil stop veya tutkal aşırı sıcaklığı durumunda tahrikler ve ısıtıcı, hiçbir dijital onaya bağlı olmadan tanımlı sürede güvenli duruma geçmeli ve yetkisiz yeniden başlatma engellenmelidir.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

LABORATUVAR 5 · PAKETPRO 3000 · Paketleme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Makine: Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

Ad Soyad **Mehmet Sefa İmamoğlu** Grup **Gündüz B** Tarih **30.10.2026**

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet etkiliyor: (1) Component X makinedeki PLC firmware kütüphanesinde var, (2) kurulu sürüm 2.4 etkilenen sürüm, (3) uzak bakım modülü internete açık olduğu için açık ulaşılabilir. Üçü de sağlanıyor.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam: plansız duruş kazan tutkalının bozulmasına ve panel hasarına yol açar. Önce uzak erişimi keser/izole ederim (açık ulaşılabilirliği kapatır), yamayı planlı bakım penceresinde uygularım.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Doğrudan değil; önce test ederim. Hat dışındaki test/staging ortamında (yedek PLC + VFD simülasyonu) yama denenir, ısı kontrolü ve devir davranışı doğrulanır, geri dönüş planı hazırlanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet etkileyebilir: firmware döngü süresini ve emniyet haberleşmesini değiştirebilir. Yama sonrası emniyet fonksiyonları (acil stop, kapak kilidi, termostat, STO) yeniden test edilir; tepki süreleri ölçülerek anlaşılır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak erişimi kapatmak, ilgili portları OT güvenlik duvarında engellemek, yazma koruma anahtarını kilitlemek, jump server + VPN + MFA zorunlu kılmak, trafiği izlemek (IDS) ve USB/servis erişimini kısıtlamak.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · PAKETPRO 3000 · Paketleme Makinesi

CRA Incident Simulation

Çıktı: Incident Workflow

Makine: Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

Ad Soyad **Mehmet Sefa İmamoğlu** Grup **Gündüz B** Tarih **06.11.2026**

Senaryo: Saat **10:15**. PaketPro'nun servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu değişmiş olabilir; **ışık perdesi parametreleri henüz doğrulanmadı**. Makine çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Önce vardiya amiri ve OT güvenlik/bakım sorumlusunu ararım. İlk üç eylem: (1) makineyi kontrollü güvenli duruma alırım, (2) ısıtıcı enerjisini keserim, (3) uzak erişimi izole ederim. Hiçbir şeyi resetlemem.

2. **İlk 2 saat:** Egzoz güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

   Emniyet zincirinin (acil stop, kapak kilidi, termostat, STO) bağımsız çalıştığını test ederim. PLC/VFD yapılandırma yedeği, log, VPN ve jump server kayıtları korunur (kanıt). Ele geçirilen servis hesabı kapatılır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Olayın özeti, etkilenen ürün/sürüm, ilk etki (emniyet etkilendi mi), şüpheli saldırı yolu ve alınan acil önlemler hazır olmalı; yetkili otoriteye erken uyarı verilir.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (açık servis hesabı/uzak erişim) – OT güvenlik uzmanı; etki ve emniyet doğrulama – emniyet mühendisi; önlem/yama – yazılım ekibi; bildirim metni – yönetim/uyum sorumlusu.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Oturum ve VPN kayıtları, PLC/VFD/Safety PLC yapılandırma ve değişiklik geçmişi, güvenlik duvarı/IDS logları, alarm kayıtları, delil zinciri ile yama ve önlem doğrulama kayıtları.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · PAKETPRO 3000 · Paketleme Makinesi

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Makine: Endüstriyel Kenar Bantlama Makinesi – PUR Tutkal Teknolojili (AİMSAD)

Ad Soyad **Mehmet Sefa İmamoğlu** | Grup **Gündüz B** | Tarih **13.11.2026**

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

*Senaryo: PaketPro'ya YZ'li görsel paket kontrolü **eklenmesi planlanıyor** — proje aşaması değerlendirmesi yapıyorsunuz.*

Kamera → YZ Modeli → OK / RED → Ret mekanizması → Hat hızı

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?
   Sistem tek modele güvenmez: bağımsız ikinci kontrol (sensör/ölçüm) ve şüpheli parçada insan onayı olur. YZ yalnızca kalite kararı verir; emniyet YZ dışında Safety PLC'de kalır.

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?
   Kamera görüntüsü süreklilik, aydınlatma ve ikinci sensörle tutarlılık kontrolüyle doğrulanır. Şüpheli girdide parça OK sayılmaz (RED/karantina), alarm verilir, gerekirse hat güvenli durdurulur, olay loglanır.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?
   Eşik risk analizine göre belirlenir (ör. %90). Eşik altında YZ kararı kullanılmaz: fallback ile parça insana yönlendirilir; art arda düşük güvende hat yavaşlatılır/durdurulur. Varsayılan RED'dir.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	İkinci bağımsız kontrol + insan onayı (human override, monitoring); emniyet YZ dışında.
Girdi manipüle edildi	Girdi doğrulama/monitoring ile tespit; şüpheli girdide RED + güvenli duruş (fail-safe) ve alarm.
Confidence düştü	Confidence threshold: eşik altında fallback – insana sor, yavaşlat/durdur; varsayılan güvenli taraf.

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.